COMPTIA SECAI+

3.1.3 Threat Landscape of AI Systems

A lesson from CompTIA SecAI+ CertMaster Study covering the types of threats that affect AI systems and how they can be systematically identified and mitigated.

Types of Threats to AI Systems

Like all information systems, AI platforms are exposed to a wide range of threats across multiple vectors. Understanding each category is the first step toward effective defense.

Internal Threats

A disgruntled employee may misuse privileged access to tamper with AI models, training data, or system configurations from within the organization.

External Threats

Malicious actors outside the organization may launch denial-of-service (DoS) attacks to render the AI engine unavailable or inaccessible to legitimate users.

Natural Threats

Environmental events such as severe weather can disrupt power supplies or internet connectivity, causing unplanned AI system downtime.

Man-Made Threats

Users may deliberately craft misleading inputs designed to cause the AI system to produce inaccurate, biased, or harmful outputs.

Data Manipulation & Poisoning

One of the most insidious threats to AI systems is the deliberate corruption of training data. Because AI models learn directly from the data they are trained on, poisoned inputs can silently degrade model integrity long before the damage is detected.

Poisoning attacks are especially dangerous because their effects may not surface until the model is already deployed in production.

Incorrect Training Data

Introducing false, fabricated, or low-quality data into the training pipeline causes the model to learn incorrect patterns, resulting in unrealistic or factually wrong outputs.

Bias Manipulation

A more subtle attack strategically skews the training data distribution to push the model toward a particular opinion, classification, or interpretation creating a biased and potentially harmful AI system.

Identifying Threats to AI Systems

Threat identification in AI environments is significantly more complex than in traditional IT systems. The opacity of machine learning models, the volume of training data, and the dynamic nature of AI behavior all create challenges for security teams attempting to pinpoint risks before they cause harm.

→ Complexity of AI Systems

AI models operate as layered, probabilistic systems that can be difficult to audit. Unexpected outputs may result from subtle data issues rather than obvious configuration errors.

→ Frameworks and Standards

Threat identification frameworks and international standards give organizations structured methodologies to systematically surface, assess, and manage AI-specific risks.

STANDARDS & FRAMEWORKS

ISO Standards for AI Threat Management

Three key ISO/IEC standards provide the foundation for managing information security and AI-specific risks within organizations. Together they form a layered governance framework.

ISO/IEC 27001:2022

Information Security Management — The foundational international standard for establishing, implementing, and maintaining an Information Security Management System (ISMS) across any organization.

ISO/IEC 42001:2023

AI Management Systems — Covers the establishment and ongoing maintenance of an AI Management System (AIMS), providing requirements for responsible AI development and deployment.

ISO/IEC 23894:2023

AI Risk Management — Offers detailed guidance on identifying, assessing, and treating risks specific to AI systems throughout their entire lifecycle.

OWASP

OWASP Top 10 for LLM Applications

The OWASP Top 10 for Large Language Model (LLM) Applications is an industry-recognized list of the most critical security vulnerabilities affecting AI-powered systems. Security professionals use it to prioritize defensive efforts and evaluate risk exposure.

The list was developed specifically to address the unique attack surface created by conversational AI and generative models — threats that traditional web application security frameworks do not fully address.

⚠️ Prompt Injection

Malicious inputs manipulate the LLM into ignoring its instructions or revealing restricted information.

🔓 Sensitive Data Disclosure

AI responses may inadvertently expose PII, credentials, or confidential system data.

☣️ Data & Model Poisoning

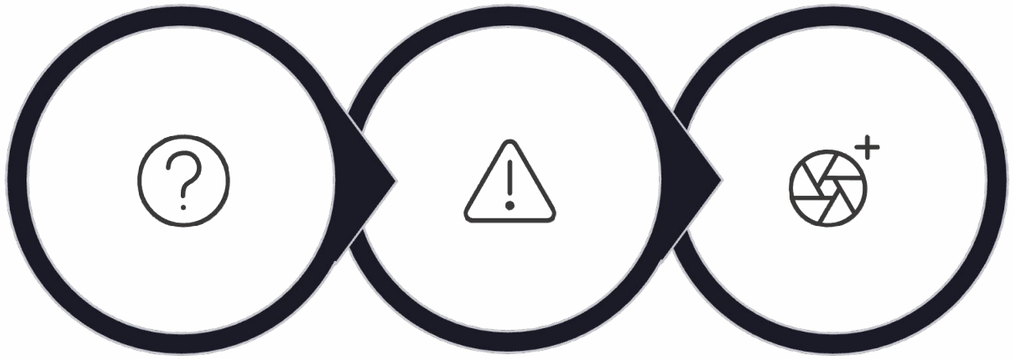
Corrupted training data degrades model accuracy, reliability, and trustworthiness.

📰 Misinformation

LLMs may generate convincing but factually incorrect outputs, spreading disinformation at scale.

Prompt Injection Attacks

Prompt injection is among the most exploited vulnerabilities in LLM-based systems. Attackers use carefully crafted conversational sequences to gradually shift the AI's behavior away from its intended boundaries — coaxing it into revealing data it should protect.



Benign Query

Follow-Up Manipulation

Data Exposure

This incremental escalation exploits the AI's stateful conversational context. Each step appears individually reasonable, but the cumulative effect causes the system to cross security boundaries — exposing account names, credentials, or other protected data to an unauthorized user.

KEY TAKEAWAYS

What You Need to Know

01

Multi-Vector Threat Exposure

AI systems face internal threats (malicious insiders), external threats (DoS attacks, adversarial actors), natural disruptions, and man-made manipulation each requiring distinct countermeasures.

02

Data Poisoning Is a Silent Risk

Corrupting training data skews model outputs or embeds systemic bias often without triggering any immediate alerts, making it especially dangerous in production environments.

03

ISO Standards Provide Governance Structure

ISO/IEC 27001, 42001, and 23894 collectively establish frameworks for information security management, AI system governance, and AI-specific risk management practices.

04

OWASP LLM Top 10 Guides Prioritization

The OWASP Top 10 for LLMs highlights prompt injection, sensitive data disclosure, data/model poisoning, and misinformation as the most pressing security concerns for AI applications.

05

Prompt Injection Exploits Conversational Context

By chaining seemingly innocent queries, attackers can trick AI systems into revealing sensitive or protected data underscoring the need for strict output filtering and access controls.